Meridian CRM

Implementation Plan v4 — Multi-tenant SaaS with domain-specific CRMs and a fast, smooth experience

Version	4.0 — extends v3 (v3 security model, engine and apps stay)
Date	4 November 2026
Decisions taken	Multi-tenant SaaS with public sign-up · Australian rules for all domains · domain-first navigation · slowness observed with `npm run dev`
Domains at sign-up	Lawyer · Migration Agent · Chartered Accountant · Loan Broker

Contents

1. Goals
2. Performance: what was measured and how it will be fixed
3. Multi-tenant architecture
4. Sign-up and sign-in
5. Domain-specific CRMs
6. Domain packs (Australia)
7. Security and isolation
8. Testing
9. Neon and deployment
10. Delivery order
11. Risks and open questions

1. Goals

- **Self-service sign-up:** a firm signs up, chooses its domain and immediately gets a CRM shaped for that profession (objects, fields, stages, terminology, dashboards, roles).
- **Complete isolation** between firms (tenants): no query, cache, file, e-mail link or background job can cross tenants.
- **Fast:** pages feel instant after the first load; API answers in tens of milliseconds even with the database in another region.
- Keep everything built so far (v3 engine, apps, security, portal, packs). Existing data becomes the first tenant.

2. Performance: measured, and how it will be fixed

Measurements (local, 4 Nov 2026)

Request	SQL queries	Local time	Estimated with Neon at 150 ms/round trip*
GET /auth/me	4	12 ms	≈ 0.6 s
GET /meta/apps	7–9	16–80 ms	≈ 1.2 s
GET /me/notifications	7	19–59 ms	≈ 1.1 s
GET /me/recent	19	33–45 ms	≈ 2.9 s
POST /objects/account/records/query (list view)	14	23–29 ms	≈ 2.1 s
GET /setup/objects	44	56–63 ms	≈ 6.6 s
Full page load in `npm run dev`	≈ 100 unbundled script files, 0.8–2.4 s; in-app navigation 40–240 ms		

* Queries run one after another, so each pays the network round trip to the database. India ↔ Sydney is typically 120–180 ms; Sydney ↔ Sydney 1–5 ms.

Conclusion: the main cause is the number of sequential database round trips per request (session, profile permissions, packs, sharing context, metadata revision, then the data), multiplied by the latency to Neon. The dev server adds a slower first load.

Fixes

Area	Change	Target
Per-request queries	Session, user, profile and role in one query. Permissions, enabled packs, sharing context (role ancestry, groups, queues) and the metadata registry cached in memory per tenant, invalidated by revision counters held in Redis (no database query to check freshness). Totals computed with the page query where possible.	≤ 3 queries for typical requests (session + data + count)
Fewer requests	A `/bootstrap` endpoint returns user, permissions, apps, branding and unread-notification count in one call; record pages load record + describe + related counts in one call.	Home / list / record: 1–3 API calls

Front-end caching	Metadata and app definitions cached across reloads (persisted query cache, versioned by metadata revision); stale-while-revalidate for lists; previous page kept while the next loads; prefetch on hover/focus of links and tabs.	Repeat visits render instantly
Perceived speed	Skeleton placeholders instead of spinners, optimistic updates for inline edits and stage changes, no layout shift.	No blank screens
Transport	gzip/brotli compression and ETags on metadata responses; HTTP keep-alive.	Smaller, cacheable payloads
Dev server	Vite pre-bundling and module warm-up for the main routes; documented option to run against a local Postgres or a Neon branch in the nearest region.	First dev load ≈ 2× faster
Guard rails	Automated query-budget tests per endpoint and a latency test that injects 150 ms per query, so regressions fail CI.	Budgets enforced

3. Multi-tenant architecture

Decision: one PostgreSQL schema per tenant (firm), plus a small shared `platform` schema.

Concern	Design
Why schema-per-tenant	Strong isolation with no tenant column to forget in thousands of queries; the existing engine, seeds and migrations work unchanged inside each schema; per-tenant backup/restore and deletion are simple. Suits a professional-firm SaaS (hundreds to low thousands of tenants).
Platform schema	`tenants` (id, slug, firm name, domain, schema name, status, region, created/verified dates), `user_directory` (e-mail → tenant + user, for sign-in), `signup_requests` (verification tokens), `provisioned_schemas` (warm pool), platform audit log.
Routing a request	The session cookie carries the tenant id with the token (`<tenant>.<token>`). Each transaction starts with `SET LOCAL search_path = <tenant schema>`, which is safe with Neon's pooled (PgBouncer transaction-mode) connections.
Caches	Every in-memory cache (registry, permissions, sharing context, settings) is keyed by tenant and revision.
Links in e-mails	Invitation, reset, verification, unsubscribe and tracking links carry the tenant, so public endpoints resolve the right schema.
Background jobs	Every job carries its tenant; scheduled jobs (reminders, escalations, retention, scheduled reports) iterate active tenants.
Files	Storage keys prefixed by tenant; downloads check the tenant.
Migrations	Platform migrations once; tenant migrations applied to every tenant schema (CLI `migrate-tenants`, also run on deploy).
Existing data	The current `public` schema becomes the first tenant, so no data is moved.

4. Sign-up and sign-in

1. **Sign-up page** (public): choose a domain from four cards (with a one-line description of what each includes), then firm name, your name, work e-mail, password, ABN (optional), and acceptance of terms and privacy policy.
2. **Verify e-mail:** a single-use link (24 h). Unverified sign-ups are removed after 7 days.
3. **Workspace creation:** takes a pre-built schema from a warm pool (instant), otherwise builds one in the background with a progress screen (target < 10 s). Installs the domain pack, applies domain-first navigation and terminology, creates the firm's administrator (System Administrator profile, MFA enrolment at first sign-in in production).
4. **First-run guide** on the home page: invite colleagues, import clients (CSV), set company/billing details, connect e-mail sending.
5. **Sign-in:** e-mail + password. If the e-mail belongs to several workspaces, a workspace picker appears. Portal clients sign in the same way and land in their firm's portal.
6. **Abuse controls:** rate limits per IP and e-mail, reserved/blocked slugs, verification before use, CAPTCHA hook.

5. Domain-specific CRMs

- **Domain-first navigation:** the domain's app is the main app (Home, Clients, Matters/Engagements/Loans..., Calendar, Reports). Generic Sales, Service, Marketing and Billing apps are hidden (not deleted) and can be switched on in Setup → App Manager.
- **Terminology:** standard objects are renamed for the profession (e.g. Contact → Client, Account → Organisation/Entity, Opportunity → Enquiry), and every label, list view and report follows.
- **Defaults:** stage paths, list views, home cards, dashboards, report library, document checklists, profiles and roles suited to the profession.
- **Branding:** the workspace carries the firm's name; colours default per domain.

6. Domain packs (Australia)

Domain	Objects and stages	Compliance and profession features
Lawyer (law practice)	**Legal Matter** (practice area, client, other parties, responsible solicitor, court/jurisdiction, key dates; stages Intake → Conflict Check → Engaged → Active → Settlement/Hearing → Closed), **Party**, **Conflict Check**, **Time Entry** (6-minute units, rate, billable, narrative), **Court Date**, **Trust Transaction**.	Conflict search across clients and parties before opening a matter; Legal Profession Uniform Law costs disclosure and estimate (required above $750) before work; trust account ledger with no overdraw and statements; time → invoice; reports: WIP, billable hours, trust balances, limitation-date alerts.
Migration Agent	Existing pack: Matter (visa stages), Visa Type, Applicants, Checklist, Service Agreement, Client Account.	Code of Conduct agreement and Consumer Guide, Lodge Applications permission, client-account ledger, expiry reminders, portal e-signature (unchanged).
Chartered Accountant	**Engagement** (type: individual/company/trust/partnership/SMSF tax return, BAS/IAS, SMSF audit, bookkeeping, advisory; financial year; stages Not Started → Awaiting Information → In Progress → Review → Ready to Lodge → Lodged → Complete), **Engagement Letter**, **Lodgement Deadline**, **Document Request**, **Time Entry**; entity fields on Organisation (entity type, ABN, TFN encrypted, GST registration, BAS frequency).	APES 305 engagement letter sign-off (portal e-signature); ATO lodgement due dates with reminders; client document requests through the portal; WIP and recoverability reports; workload by accountant.
Loan Broker	**Loan Application** (borrowers, purpose, loan amount, security value, LVR calculated, lender, product, rate, term; stages Enquiry → Fact Find → Preliminary Assessment → Lodged → Conditional Approval → Valuation → Unconditional → Settlement → Settled / Declined), **Lender**, **Fact Find** (income, expenses, assets, liabilities), **Commission** (upfront, trail, clawback).	NCCP: credit guide and privacy consent recorded before credit assistance; Best Interests Duty record and preliminary assessment kept 7 years; settlement and rate-review reminders; commission ledger and pipeline-by-stage reports.

Each pack also ships domain profiles (e.g. Principal, Solicitor, Paralegal / Partner, Accountant, Bookkeeper / Principal Broker, Broker, Processor), roles, list views, dashboards and portal access for clients. The packs support compliance workflows; they do not replace professional advice on the rules.

7. Security and isolation

- Tenant resolved from the signed session cookie only (never from user input); the tenant id must exist and be active.
- The database role used by the API has no access to the platform tables beyond what sign-in needs.
- Automated cross-tenant tests: every endpoint called with another tenant's ids, sessions, links and file ids must return 404/401.
- Per-tenant export and deletion (closing a workspace), and per-tenant audit logs.

8. Testing

- Back end: tenancy unit tests (routing, caches, search_path), cross-tenant isolation suite, sign-up/verification/provisioning, each domain pack's rules, query-budget tests.
- Front end: sign-up flow, workspace picker, domain-first navigation and terminology per domain.
- End-to-end: sign up once per domain, verify e-mail, sign in, create the domain's core record and move it through its stages; isolation check between two firms; performance run with injected latency.

9. Neon and deployment

- Neon main currently holds the single-tenant schema at revision 8ad0e7e5a8f8 with 7 users. After this work a SQL script (generated and verified the same way as before) upgrades it: platform schema plus the existing data as the first tenant.
- New tenants are created by the application itself. The container used for development cannot reach Neon, so production provisioning runs from the deployed API.

10. Delivery order

#	Step	Deliverables
1	Performance	Query reduction and caches, bootstrap endpoint, front-end caching/prefetch/skeletons, dev-server warm-up, query-budget tests.
2	Tenancy core	Platform schema, tenant routing, per-tenant caches/jobs/files/links, tenant migrations, existing data as first tenant, isolation tests.
3	Sign-up and sign-in	Sign-up with domain choice, e-mail verification, provisioning (warm pool), workspace picker, first-run guide.
4	Domain packs	Legal, Accounting and Loan Broker packs; domain-first navigation and terminology for all four domains.
5	Verification	Full test suites, end-to-end per domain, performance run, docs, Neon upgrade script.

11. Risks and open questions

Item	Approach / decision needed
Schema count at very large scale	Fine for thousands of firms; beyond that, shard tenants across Neon projects (the platform table records each tenant's location).

Sign-up e-mails need a real provider	Production needs SMTP (e.g. Amazon SES Sydney) for verification e-mails.
Open: SaaS subscriptions	Not in this plan: plans/pricing, trials and card billing (e.g. Stripe). Confirm if wanted.
Open: workspace URLs	This plan uses one address for all firms with a workspace picker; per-firm sub-domains (firm.example.com) can be added later.